CASEVAULT

Threat Model & Quantitative Risk Assessment

CYC386 — Secure Software Design and Development | Midterm Lab Exam | Fall 2026

Document v1.0 • Prepared 30 October 2026 • Design threat model, **not** a verified security finding

Team: [Enter names] • Instructor approval evidence: [Add actual link when received]

Evidence integrity: No claims of executed exploits, scanner findings, GitHub/Jira approvals or passing implementation tests are made here. All CVSS scores are conditional on the specified defective implementations.

1. Executive security summary

CaseVault protects incident-evidence exchange using authenticated sessions, private storage, object-level access, a native C metadata subprocess, SHA-256 integrity checking and audit events. The Phase 3 assessment covers 36 DFD elements, 26 STRIDE scenarios, 16 CVSS-scored hypothetical software weaknesses, and two high-impact attack trees.

Model scope: local Docker lab with synthetic evidence. Production internet exposure, immutable audit, enterprise SSO and verified backups remain outside the initial sprint unless separately implemented and tested.

2. Architecture baseline and boundaries

Actors: owner/investigator (E1), collaborator (E2 in context; same browser boundary as E1 at level-1), untrusted website (E3), and operator (E4). Main runtime processes P1 session/authentication, P2 intake/integrity, P3 object authorization, P4 C helper, P5 audit/status. Data stores D1 accounts, D2 evidence/grants/digests, D3 evidence bytes, D4 audit.

Trust boundaries: TB-1 browser/server, TB-2 server/private persistence, TB-3 app/native subprocess. GitHub CI and Jira are design/development surfaces separate from runtime DFD. SQLite logical stores can reside in one physical database.

3. Context and Level-1 data-flow diagrams

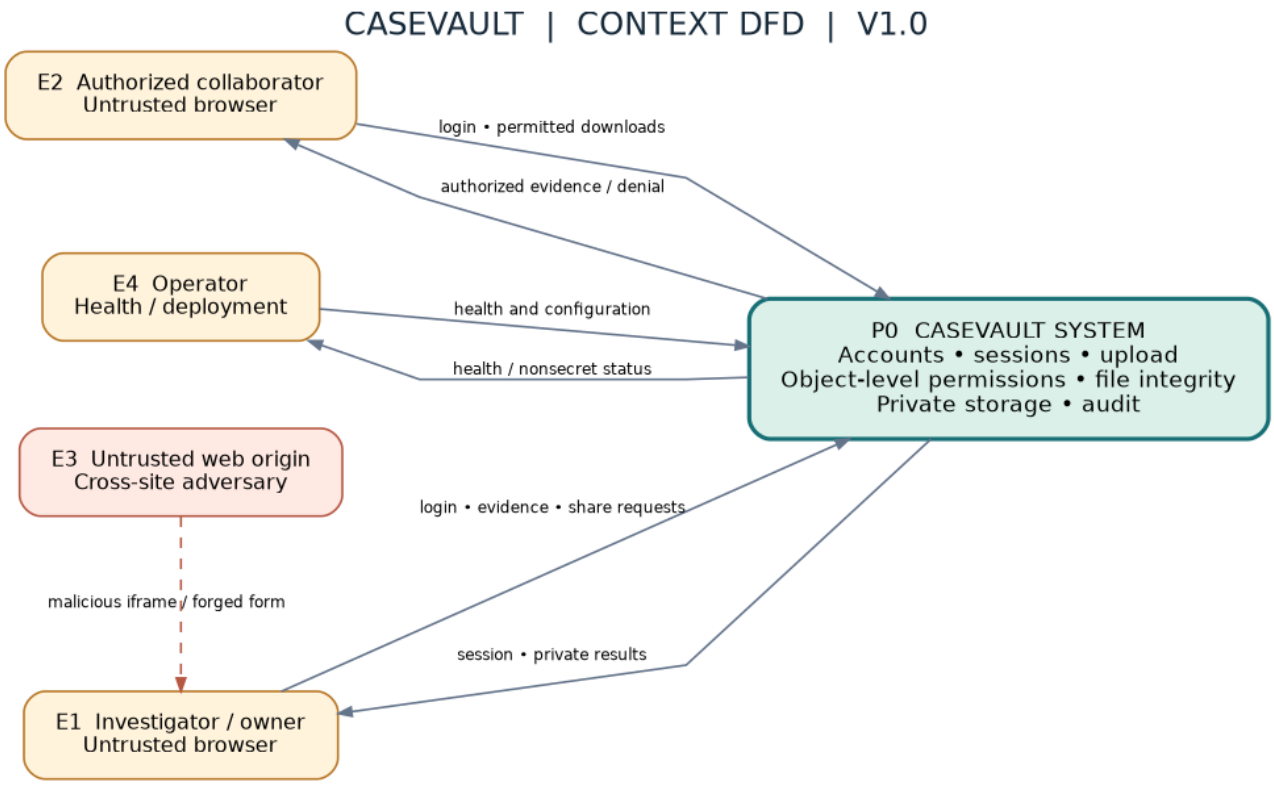


Figure 1. System context DFD. External browsers and hostile cross-origin page.

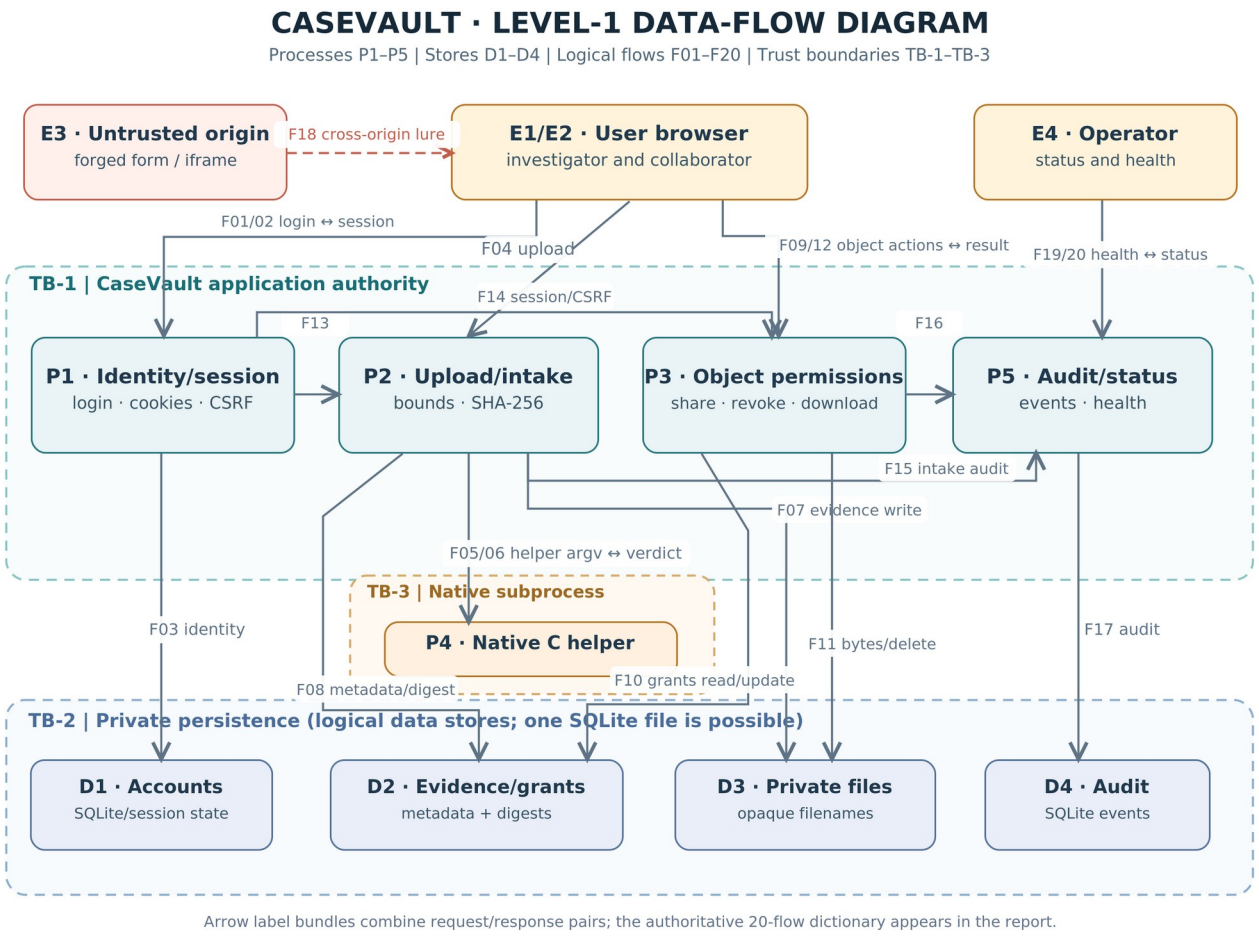


Figure 2. Level-1 DFD with process, store, flow and trust-boundary IDs.

3.1 Flow dictionary

Flow	Data exchange	Threat IDs
F01	E1→P1	TH-001, TH-002, TH-022
F02	P1→E1	TH-001
F03	P1<->D1	TH-001, TH-002
F04	E1→P2	TH-003, TH-010, TH-015
F05	P2→P4	TH-013, TH-014
F06	P4→P2	TH-013, TH-019
F07	P2→D3	TH-015, TH-016
F08	P2→D2	TH-012, TH-016
F09	E1→P3	TH-006, TH-007, TH-012
F10	P3<->D2	TH-006, TH-011, TH-023
F11	P3<->D3	TH-005, TH-007, TH-024
F12	P3→E1	TH-005, TH-022
F13	P1→P2	TH-001, TH-008
F14	P1→P3	TH-001, TH-008, TH-006
F15	P2→P5	TH-004, TH-017
F16	P3→P5	TH-004, TH-017
F17	P5→D4	TH-017, TH-018
F18	E3→E1	TH-008, TH-009
F19	E4→P5	TH-024
F20	P5→E4	TH-018, TH-024

4. STRIDE: systematic DFD element analysis

STRIDE = Spoofing (S), Tampering (T), Repudiation (R), Information disclosure (I), Denial of service (D), Elevation of privilege (E). X = applicable analytical prompt; — = not directly applicable to this kind of element in current scope, not a security guarantee. Threat IDs point to the detailed catalog. Every F01–F20 flow and every process, store and boundary is represented.

Element	S	T	R	I	D	E	Linked threats
E1	X	—	X	X	—	X	TH-001, TH-008, TH-009
E2	X	—	X	X	—	X	TH-001, TH-006, TH-023
E3	X	X	—	X	—	—	TH-008, TH-009
E4	X	—	X	X	—	—	TH-004, TH-018
P1	X	X	X	X	X	X	TH-001, TH-002, TH-008, TH-020
P2	—	X	X	X	X	X	TH-003, TH-010, TH-015, TH-016
P3	X	X	X	X	X	X	TH-004, TH-006, TH-007, TH-011, TH-023
P4	—	X	—	X	X	X	TH-013, TH-014, TH-019, TH-026
P5	—	X	X	X	X	—	TH-004, TH-017, TH-018, TH-024
D1	—	X	X	X	X	—	TH-001, TH-002, TH-020
D2	—	X	X	X	X	—	TH-006, TH-011, TH-012, TH-016, TH-023
D3	—	X	X	X	X	—	TH-005, TH-007, TH-015, TH-024, TH-025
D4	—	X	X	X	X	—	TH-017, TH-018
TB-1	X	X	—	X	—	X	TH-001, TH-008, TH-009, TH-022
TB-2	—	X	—	X	—	X	TH-005, TH-006, TH-011, TH-015
TB-3	—	X	—	—	X	X	TH-013, TH-014, TH-019, TH-026
F01	X	X	—	X	—	—	TH-001, TH-002, TH-022
F02	X	—	—	X	—	—	TH-001
F03	—	X	—	X	—	—	TH-001, TH-002
F04	—	X	—	—	X	—	TH-003, TH-010, TH-015
F05	—	X	—	—	—	X	TH-013, TH-014
F06	—	X	—	—	X	—	TH-013, TH-019
F07	—	X	—	X	—	—	TH-015, TH-016
F08	—	X	—	X	—	—	TH-012, TH-016
F09	X	X	—	—	—	X	TH-006, TH-007, TH-012
F10	—	X	—	X	—	X	TH-006, TH-011, TH-023
F11	—	X	—	X	X	—	TH-005, TH-007, TH-024
F12	—	—	—	X	—	—	TH-005, TH-022
F13	X	X	—	—	—	—	TH-001, TH-008
F14	X	X	—	—	—	X	TH-001, TH-008, TH-006
F15	—	X	X	—	—	—	TH-004, TH-017
F16	—	X	X	—	—	—	TH-004, TH-017
F17	—	X	X	X	—	—	TH-017, TH-018
F18	X	X	—	—	—	X	TH-008, TH-009
F19	X	—	—	—	X	—	TH-024
F20	—	—	—	X	—	—	TH-018, TH-024

4.1 Threat catalog and proposed controls

ID / category	DFD surface	Threat description	PNE / planned control
TH-001 S	P1/D1/F01,F02	Session impersonation via weak signing secret or session misuse	PNE-005;PNE-007;PNE-021 • Require strong secret, expiry and server check; verify altered cookie denied
TH-002 S	P1/F01	Credential stuffing or guessing	PNE-006;PNE-028 • Vetted password hashing and monitoring/throttling
TH-003 T	F04/P2	Client alters upload metadata or declared size	PNE-012;PNE-020 • Validate lengths and bytes on server
TH-004 R	P3/P5/F16,F17	User disputes share/delete due to missing event record	PNE-017 • Record actor, object, action, outcome and timestamp
TH-005 I	D3/P3/F11	Private evidence leaked through direct static path	PNE-010;PNE-011 • Server-only authorized download; private file store
TH-006 E	P3/D2/F09,F10	IDOR read/share access when object ACL not checked	PNE-001;PNE-002;PNE-003 • Owner and grant checks on each operation
TH-007 T	P3/D3/F11	Non-owner deletes another investigator's file	PNE-004 • Owner-only delete and unchanged-data negative test
TH-008 T	P1/P3/F18	CSRF sensitive grant/revoke/delete	PNE-008 • Anti-CSRF synchronizer token; SameSite; reject missing/wrong token
TH-009 E	E3/E1/F18	Clickjacking through framed authenticated UI	PNE-009 • CSP frame-ancestors none; XFO DENY
TH-010 D	P2/F04	Oversized/repeated evidence uploads exhaust disk or worker	PNE-012;PNE-024 • Request maximum, disk cleanup and health check
TH-011 T	P3/D2/F10	Dynamic SQL query construction allows input manipulation	PNE-019 • Parameterized SQL, negative input test
TH-012 I	D2/F09,F10	Opaque ID or guessable path leaks evidence metadata	PNE-011;PNE-015 • Generated opaque storage ID and server authorization
TH-013 E	P4/F05,F06	Native helper memory corruption via unbounded input	PNE-013;PNE-020 • Bounded C input, ASAN and compiler hardening
TH-014 E	P4/F05	Shell interpretation of upload metadata invokes extra command	PNE-014 • Fixed argv; no shell; allowlist
TH-015 T	P2/D3/F04,F07	Filename/path traversal writes outside private store	PNE-010;PNE-015 • Opaque server-generated filesystem paths
TH-016 T	D2/D3/P2	Hash or file byte change not detected	PNE-016 • Ingest digest + recompute before authorized use
TH-017 R	P5/D4/F17	Mutable local audit table tampered or missing events	PNE-017;PNE-030 • Detailed audit, protected storage; later external immutable archive
TH-018 I	P5/D4	Logs or traceback expose credentials/evidence	PNE-018 • Error sanitization and log redaction
TH-019 D	P4/F06	Malformed native-helper data crashes or stalls request	PNE-020;PNE-024 • Process timeout, bounds and controlled error
TH-020 D	P1/F01	Automated login abuse depletes resources or guesses credentials	PNE-028 • Monitor/rate limit (P1 deployment hardening)
TH-021 T	A-14/CI	Unreviewed GitHub change bypasses security tests	PNE-022;PNE-023 • Require protected branch, PR approval and fail-on-high critical gate
TH-022 I	TB-1/F01,F12	Remote plaintext traffic leaks sessions/evidence	PNE-026 • HTTPS before internet exposure
TH-023 E	P3/D2/F10	Cached authorization persists after revoked share	PNE-003 • Grant state checked at each request
TH-024 D	D3/D2	Disk/database loss prevents evidence recovery	PNE-027 • Backup and restore drill before production
TH-025 T	P3/D3	Incorrect retention/delete semantics cause unexpected evidence loss	PNE-029 • Document retention and deletion scope
TH-026 E	P4/A-13	Privileged helper or container magnifies compromise	PNE-025 • Non-root user, minimum capabilities and private writable paths

5. Attack trees (at least two high-impact threats)

5.1 AT-01 — shell command injection in metadata processing

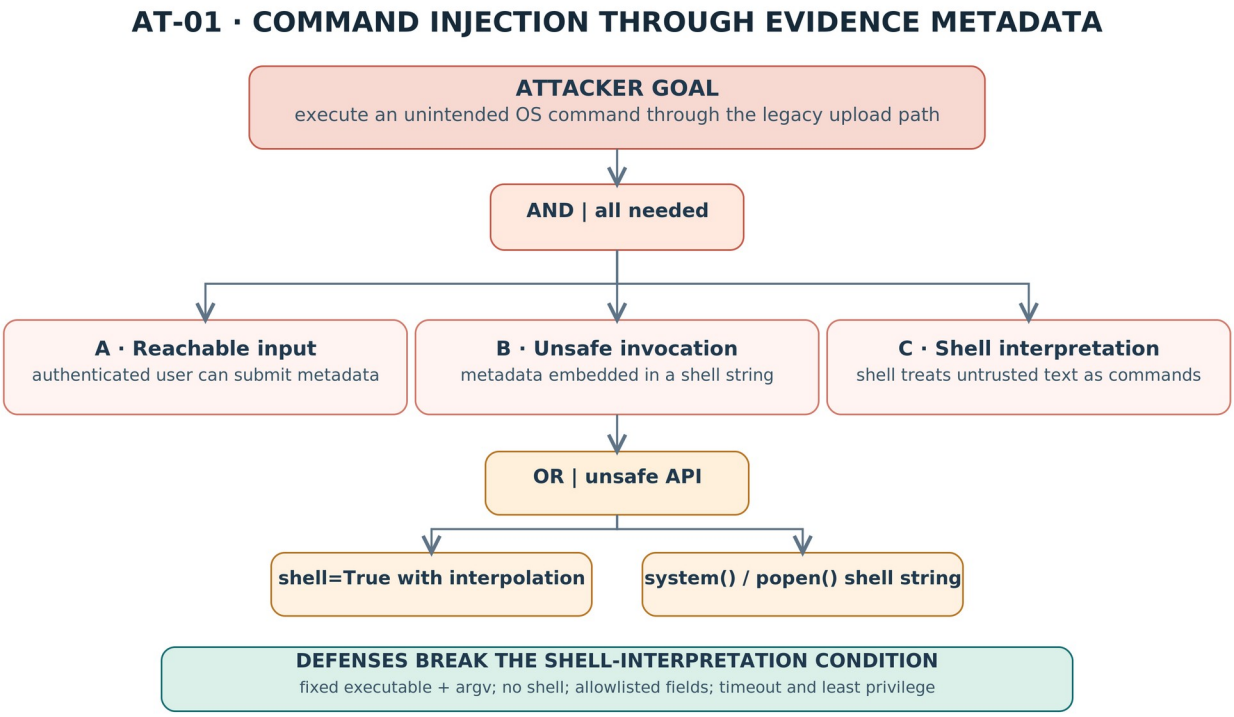


Figure 3. AT-01: AND preconditions and OR implementation paths.

An authenticated upload reaches metadata processing AND a defective implementation builds a shell string AND the interpreter processes the untrusted string. Alternative vulnerable paths include shell=True and system()/popen(). Corrective action: fixed executable, argv list with shell disabled, validation and timeout. TH-014 → R-01 → PNE-014 → T-014. No successful command execution is asserted.

5.2 AT-02 — unauthorized evidence exposure or alteration

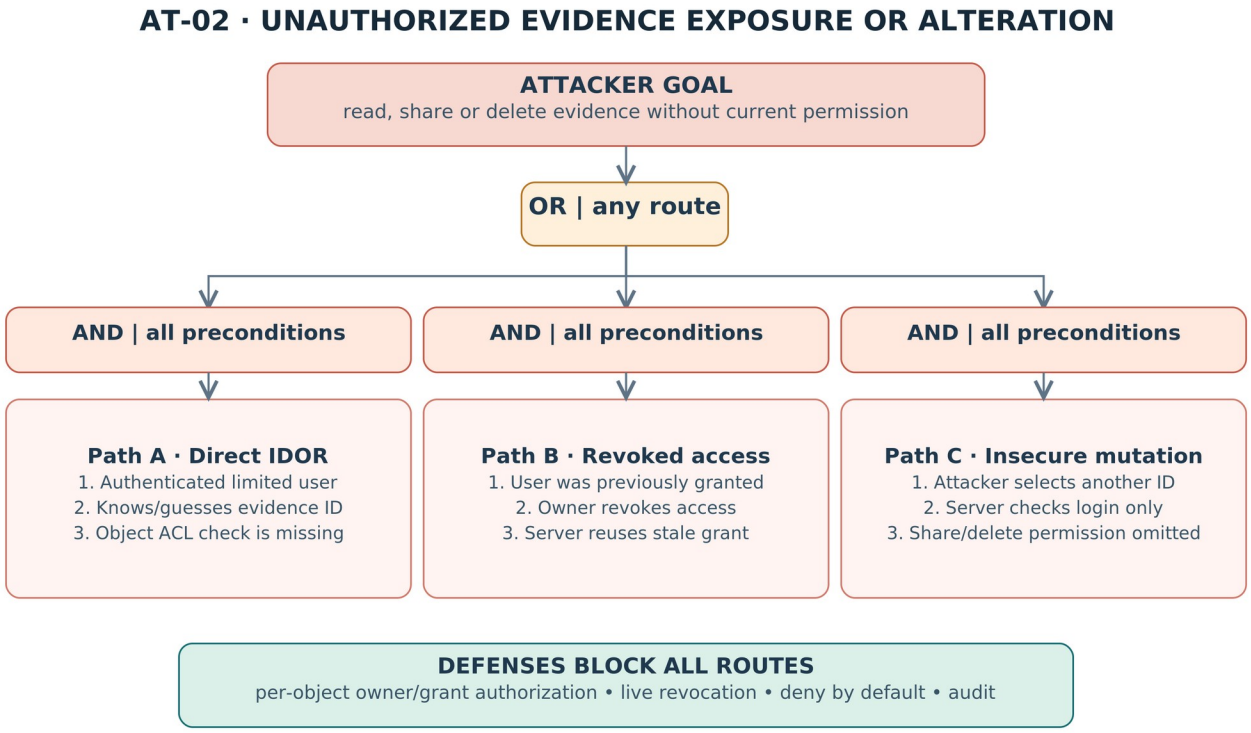


Figure 4. AT-02: unauthorized read, stale grant and insecure share/write paths.

Alternative branches are a direct IDOR request, access surviving revocation, or unauthorized share/delete. Each needs applicable account or prior grant and failure to recheck ownership/current permission. Enforce object-level ACL at every sensitive action. TH-006 / TH-007 / TH-023 → R-03 / R-04 / R-18 → PNE-001–004.

6. CVSS v3.1 method and score register

Scores use the official FIRST v3.1 Base formula and exact vector strings AV/AC/PR/UI/S/C/I/A. All describe hypothetical flawed code before remediation; there are no confirmed vulnerabilities here. Base bands: Critical >=9.0, High >=7.0, Medium >=4.0, Low >0. Temporal and Environmental scores have not been assumed.

Rank	Risk / modeled pre-fix flaw	CVSS:3.1 vector	Base	Band
1	R-01 • Shell command injection in legacy metadata processing	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	8.8	High
2	R-07 • SQL injection in metadata queries	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	8.8	High
3	R-08 • Filename/path traversal reaches private files	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L	8.3	High
4	R-03 • IDOR permits unauthorized read plus grant modification	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	8.1	High
5	R-04 • IDOR permits unauthorized evidence delete	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H	8.1	High
6	R-05 • CSRF causes unauthorized grant or deletion	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N	8.1	High
7	R-02 • Native helper buffer overflow	CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H	7.5	High
8	R-10 • Session forgery under weak secret	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	7.4	High
9	R-15 • Missing authentication rate limit	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	7.4	High
10	R-06 • Clickjacking causes	CVSS:3.1/AV:N/AC:L/PR:N/	7.1	High

Rank	Risk / modeled pre-fix flaw	CVSS:3.1 vector	Base	Band
	victim action	UI:R/S:U/C:L/I:H/A:N		
11	R-17 • Remote traffic intercept without TLS	CVSS:3.1/AV:A/AC:L/PR:N/ UI:N/S:U/C:H/I:L/A:N	7.1	High
12	R-09 • Oversized upload exhausts storage or workers	CVSS:3.1/AV:N/AC:L/PR:L/ UI:N/S:U/C:N/I:N/A:H	6.5	Medium
13	R-18 • Non-privileged read path bypasses revocation	CVSS:3.1/AV:N/AC:L/PR:L/ UI:N/S:U/C:H/I:N/A:N	6.5	Medium
14	R-11 • Tampering with evidence not detected	CVSS:3.1/AV:L/AC:L/PR:L/ UI:N/S:U/C:N/I:H/A:N	5.5	Medium
15	R-13 • Sensitive data leaked through error or audit log	CVSS:3.1/AV:L/AC:L/PR:L/ UI:N/S:U/C:H/I:N/A:N	5.5	Medium
16	R-14 • Upload validator failure allows process termination	CVSS:3.1/AV:N/AC:L/PR:L/ UI:N/S:U/C:N/I:N/A:L	4.3	Medium

6.1 High and Critical scoring justifications

R-01 • 8.8 High: Authenticated attacker controls an upload field; if sent through the shell, code runs with service privileges. Scope U assumes app and helper run in one application security authority. Mitigation: Replace shell with argv array, fixed executable, input validation, timeout; least-privilege runtime Planned test: T-014;T-020.

R-07 • 8.8 High: Untrusted string enters SQL if dynamic concatenation exists; network-reachable to authenticated user and can affect whole CaseVault data store. Mitigation: Parameterized statements and input validation Planned test: T-019.

R-08 • 8.3 High: Authenticated upload controls filename; if reused as filesystem path, unintended private objects could be overwritten/read. Mitigation: Opaque paths generated by server; private store outside public root; normalization Planned test: T-010;T-011;T-015.

R-03 • 8.1 High: Authenticated unprivileged user manipulates evidence ID; absent object-level checks could expose files and modify grants; no assumed availability impact. Mitigation: Centralize owner/grantee checks for each object; live revocation; deny by default Planned test: T-001;T-002;T-003.

R-04 • 8.1 High: Authenticated user could delete another user's evidence where ownership validation is absent; high integrity and availability impact. Mitigation: Owner-only deletion, transactional metadata+file cleanup and denial tests Planned test: T-004.

R-05 • 8.1 High: Remote attacker needs a signed-in victim to visit attacker-controlled origin; attacker holds no CaseVault account. Assumes forged sensitive action changes grant state. Mitigation: Session-bound CSRF tokens, SameSite, POST-only state changes, Origin checks where relevant Planned test: T-008.

R-02 • 7.5 High: Authenticated upload reaches unsafe C buffer; memory exploitation is assumed to need additional heap/stack conditions (AC:H). Worst-case impact is modeled, not confirmed RCE. Mitigation: Enforce length limits in Python/C; bounded copy; ASAN; compiler hardening; isolate helper Planned test: T-013;T-020.

R-10 • 7.4 High: Network attacker needs exposed/guessable session signing secret; extra condition motivates AC:H, but high account compromise impact. Mitigation: High-entropy environment secret; signed expiry; HttpOnly, session invalidation Planned test: T-005;T-006;T-007;T-021.

R-15 • 7.4 High: Automated guessing needs correct credentials to succeed; account lockout/throttling is deployment hardening P1. Mitigation: Per-account/IP throttling, event monitoring, MFA if deployed externally Planned test: T-028.

R-06 • 7.1 High: Requires victim click on framed authenticated UI, with potential unauthorized share; lower direct disclosure than direct IDOR. Mitigation: CSP frame-ancestors none and X-Frame-Options DENY; browser test Planned test: T-009.

R-17 • 7.1 High: Adjacent network position assumed when deployed over plaintext HTTP; local HTTP is acceptable only in isolated lab. Mitigation: Terminate HTTPS in real deployment; Secure cookies and redirects Planned test: T-026.

6.2 Medium scenarios (still important)

R-09 • 6.5 Medium: Authenticated user sends repeated/large uploads if limits absent; potential serious service availability loss. Test: T-012;T-024.

R-18 • 6.5 Medium: Previously granted user can reuse stale authorization after revoke if service caches outdated permission checks. Test: T-003.

R-11 • 5.5 Medium: User with local write access could modify file bytes if digest verification not performed; local attack and existing access assumed. Test: T-016.

R-13 • 5.5 Medium: Local log reader with limited access could view accidentally printed tokens, paths or secret data. Test: T-018.

R-14 • 4.3 Medium: Malformed metadata triggers uncaught helper crash or unbounded wait; assumed partial uptime impact. Test: T-020.

7. Prioritized remediation and Jira traceability

Risk_Register_CVSS_v3_1.csv is the authoritative worklist: each entry has TH/PNE IDs, vector rationale, mitigation, planned T-IDs, and empty slots for actual Jira key, PR, log and residual-risk assessment. PNE_Traceability_Updated.csv maps each Phase 2 PNE to threat IDs without rewriting PNE content. Jira_Threat_Tasks_Planned.csv contains proposed issue descriptions; no real issue has yet been created by this package.

Priority	Risk / threat	Mapped PNEs	Planned verification
P0	R-01 / TH-014	PNE-014;PNE-020	T-014;T-020
P0	R-07 / TH-011	PNE-019	T-019
P0	R-08 / TH-015	PNE-010;PNE-011;PNE-015	T-010;T-011;T-015
P0	R-03 / TH-006	PNE-001;PNE-002;PNE-003	T-001;T-002;T-003
P0	R-04 / TH-007	PNE-004	T-004
P0	R-05 / TH-008	PNE-008	T-008
P0	R-02 / TH-013	PNE-013;PNE-020	T-013;T-020
P0	R-10 / TH-001	PNE-005;PNE-006;PNE-007;PNE-021	T-005;T-006;T-007;T-021
P1	R-15 / TH-020	PNE-028	T-028
P0	R-06 / TH-009	PNE-009	T-009
P1	R-17 / TH-022	PNE-026	T-026
P0	R-09 / TH-010	PNE-012;PNE-024	T-012;T-024
P1	R-18 / TH-023	PNE-003	T-003
P0	R-11 / TH-016	PNE-016	T-016
P0	R-13 / TH-018	PNE-018	T-018
P0	R-14 / TH-019	PNE-020	T-020

8. Residual risk, limitations and release gates

There is no verified post-remediation risk score. The following are deployment/process residual risks that must be explicitly accepted or treated later; they are not assigned software CVSS simply for severity appearance.

ID	Current residual-risk statement	Mitigation before deployment
QUAL-01	DB/file loss without tested backups. Impact can be irreversible evidence loss; CVSS inapplicable without a defined software vulnerability	Backup plus restore drill
QUAL-02	Unagreed retention/disposal policy. Governance risk rather than software exploit	Document retention period and deletion scope
QUAL-03	Over-privileged container/native subprocess. Environmental consequence modifier; no single concrete exploitable flaw proved	Run helper non-root; drop capabilities; isolate file permissions
QUAL-04	Audit SQLite can be modified by host administrator. Mutable local audit cannot provide tamper-proof chain of custody	Forward to independent protected logging before production
QUAL-05	Unreviewed changes bypass pipeline	Protect main, use reviewed PRs and nonzero

ID	Current residual-risk statement	Mitigation before deployment
	enforcement. CI governance control weakness; not a measurable standalone product CVSS vulnerability	high/critical security gates

Other constraints: local HTTP is strictly lab-only; mutable SQLite audits are not independently tamper-proof; SHA-256 detects change only against a trusted stored digest and is not a legal chain-of-custody proof; actual hostile file-content scanning is outside MVP. Do not place genuine confidential incident files in the student test system.

Release gate: verify and fix all five lab vulnerabilities, retain actual before/after proof and high/critical SAST/DAST findings, require failing CI gate on high/critical; obtain actual authorization to accept unresolved risks. A green scan alone is not proof of secure design.

9. Evidence collection and exam traceability

• Export this model in the real GitHub branch and record the actual commit/PR, team review and dates; do not backfill or invent history.

• Run python scripts/check_model_integrity.py and redirect output to model_integrity_log.txt; this is a cross-reference checker, not proof of working security.

• Use FIRST CVSS calculator and capture vectors and scores for R-01, R-02 and R-03; keep actual filenames in Evidence_Manifest.csv.

• Create real Jira TH tasks and link corresponding PNE Stories and risk IDs; keep screenshots with visible identifiers and statuses.

• During later phases retain C ASAN traces, all five before/after security tests, scanner raw reports, GitHub Actions URLs/logs and the dated demo. These are future deliverables.

10. CYC386 rubric compliance

Exam Section 6.3 requires context + level-1 DFD, STRIDE on DFD elements, Attack Trees for at least two high-impact threats, v3.1 scoring for high/critical with justified vectors, risk register linked to Jira and PR, and residual risk. This model covers the design-time artifacts and leaves execution evidence to later phases. The one-tree wording in Section 5 is weaker than two-tree requirement in Sections 4 and 6.3; two are provided.

References

CYC386 Midterm Lab Exam — 1-Week DevSecOps Security Sprint (Fall 2026), instructor-issued, Sections 2–7.

CaseVault Phase 1 Architecture Blueprint (locked design) and Phase 2 PNE_Report.md.

FIRST CVSS v3.1 Specification: https://www.first.org/cvss/v3.1/specification.document

OWASP Threat Modeling Cheat Sheet:
https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html